NIST SP 800-53 Rev 5 LOW Baseline Control Implementation Statements

Community Tech Aid (CTA)

System: Community Tech Aid, a consumer-facing AI tech-support web application
Legal entity: eBiz Market, LLC (Idaho), single owner and operator, no employees
Assumed business name: Community Tech Aid
Primary URL: https://communitytechaid.ai
Framework: NIST SP 800-53 Revision 5, FedRAMP Low / NIST Low baseline
Document type: Control implementation statements for a cybersecurity portfolio
Prepared: 2026-07-27
Author: System owner (eBiz Market, LLC)
Revised: 2026-07-27 (remediation update; several gaps closed, see Section 9 Remediation Log 2026-07-27)

> Control identifiers and titles in this document were verified against the NIST SP 800-53 Rev 5 catalog on 2026-07-27. This document describes the system as it actually exists. It uses present tense for what is implemented and states gaps plainly. It contains no aspirational or future-tense claims about controls that are not in place.

1. System Description and Categorization

Community Tech Aid (CTA) is a consumer AI tech-support application. Users create an account, sign in, and receive AI-driven troubleshooting for scams, slow computers, popups, WordPress, WiFi, TVs and soundbars, with an optional handoff to a real person by email. Paid access is sold through Stripe. AI responses are generated by the Anthropic API from a server-side edge function. The application is built and hosted on Lovable, with a backend running on Lovable Cloud (a managed Supabase instance).

Security categorization (owner-asserted, FIPS 199): Confidentiality LOW, Integrity LOW, Availability LOW. The system processes limited personal information (email address, source IP, user-submitted chat and form content) for a commercial consumer service. It stores no federal information, no cardholder data, no health records, and no government-classified data. The LOW categorization is asserted by the owner and has not been through a formal, documented categorization exercise under RA-2. See Known Gaps.

Baseline scope: This document addresses the base controls of the NIST 800-53 Rev 5 LOW baseline that apply to this system, as enumerated by the owner. Relevant control enhancements (for example multifactor authentication under IA-2) are discussed within their base control. Program Management (PM) controls are organization-wide and are out of scope for this system-level document.

2. Authorization Boundary

The authorization boundary is the CTA web application and the application data and functions it runs, together with the managed platform components that host them. Because the backend is a managed service the owner does not directly control, the boundary is described in three layers: what the system builds and operates, what it inherits from providers, and what sits outside as external interconnections.

2.1 Inside the boundary (system-owned application and data)

Component	Description
CTA frontend	React/TypeScript single-page application, built and hosted on Lovable
Edge functions	`supabase/functions/chat/index.ts` (AI calls, free-tier gate), `log-auth-event`, `log-analytics`, `verify-paid-session`, and the `validatePaidTokenWithServer()` server-side token check
Client access logic	`ChatAccessGate` (route protection for /chat and /triage), `useIdleLogout` (idle session timeout)
Application database (Postgres)	Tables: `profiles`, `auth_events`, `chat_sessions`, `contact_messages`, `demographics_submissions`, `page_visits`, `access_tokens`, `suppression_list`, `topic_analytics`, `spam_attempts`, `user_roles`
Authentication	Supabase Auth, email plus password, anonymous sign-in disabled, redirect URL allowlist
Application data	Account records, authentication events, chat content, contact and demographics submissions, analytics

2.2 Platform the system runs on (inherited infrastructure)

Provider	Role in the boundary
Lovable	Build pipeline and hosting for the frontend; the Lovable Cloud management plane
Lovable Cloud (managed Supabase)	Postgres database, Supabase Auth, Edge Functions runtime, platform backups. Provisioned and managed by Lovable. The owner has no service role key, no direct database URL, and no separate Supabase dashboard. All backend administration is performed through More > Cloud inside the Lovable editor.
Cloudflare	Registrar, authoritative DNS, and edge/CDN for the primary domain, including edge TLS termination, DDoS protection, and Cloudflare Analytics

2.3 Outside the boundary (external interconnections and excluded assets)

External system	Relationship
Anthropic API (claude-sonnet-4-5)	AI inference. Chat text is sent from the `chat` edge function. Interconnection under CA-3.
Stripe	Payment processing via off-site hosted checkout. Cardholder data never enters the system. Interconnection under CA-3.
Resend	Transactional email (signup confirmation, magic-link recovery). Interconnection under CA-3.
Proton mailboxes	`support@communitytechaid.ai` and `communitytechaid-help@proton.me`. Human-support handoff target. Outside the boundary. Interconnection under CA-3.

Zoom	Live training delivery, requested by email. Outside the boundary. Interconnection under CA-3.
Secondary/defensive domains	`communitytechaid.com`, `.info`, `.net`, `.tech` are defensive registrations and redirects. `communitytechaid.tech` forwards mail to the same Proton inbox. Not part of the live application boundary.
`ebizmarket.net` and one additional Cloudflare domain	Parent-company and other owner domains in the same Cloudflare account. Not part of the CTA boundary. Seventh domain identity is owner-input-required.
Cloudflare Worker `empty-disk-1010`	Present in the Cloudflare account with 0 invocations. In-boundary status is owner-input-required.

3. Customer Responsibility Matrix

This matrix assigns each covered LOW baseline control to Provider, Shared, or Customer responsibility, with exactly one marking per row. "Provider" means the control is fully inherited from a named service provider. "Shared" means the provider supplies part and the Owner (the customer) supplies the rest, with the Owner's residual obligation stated in the Notes. "Customer" means the Owner is responsible, including controls determined Not Applicable, where the Owner owns that determination. Provider names use the stack described in Section 2. Consistent with the rest of this document, this section does not map any named provider to multifactor authentication state; administrative multifactor authentication is enabled on all provider accounts.

Control	Control Name	Provider	Shared	Customer	Notes
AC-1	Policy and Procedures			X	Customer-authored AC policy (cta-policies.md).
AC-2	Account Management		X		Provider: Lovable Cloud (Supabase Auth mechanism). Owner manages account lifecycle and roles.
AC-3	Access Enforcement			X	Owner-implemented Row Level Security and server-side access gate.
AC-7	Unsuccessful Logon Attempts		X		Provider: Lovable Cloud (Supabase throttling). Owner logs failure events; cannot set lockout threshold.
AC-8	System Use Notification			X	Owner responsibility; login banner not implemented (gap).
AC-14	Permitted Actions Without Identification or Authentication			X	Owner-defined public versus gated routes.
AC-17	Remote Access		X		Provider: Cloudflare (edge TLS). Owner secures console access; multifactor authentication on all administrative provider accounts.
AC-18	Wireless Access			X	Not applicable: no organization-operated wireless.
AC-19	Access Control for Mobile Devices			X	Not applicable: no organization-managed mobile devices.
AC-20	Use of External Systems			X	Owner governs use of external services.
AC-22	Publicly Accessible Content			X	Owner authors and publishes all public content.
AT-1	Policy and Procedures			X	Customer-authored AT policy (cta-policies.md).
AT-2	Literacy Training and Awareness			X	Not applicable: no workforce; Owner self-maintains competence.
AT-3	Role-based Training			X	Not applicable: no workforce roles.
AT-4	Training Records			X	Not applicable: no workforce.
AU-1	Policy and Procedures			X	Customer-authored AU policy (cta-policies.md).
AU-2	Event Logging		X		Provider: Lovable Cloud (platform logs). Owner defines and writes application auth and analytics events.
AU-3	Content of Audit Records		X		Provider: Lovable Cloud (platform log content). Owner sets application record content.
AU-4	Audit Log Storage Capacity	X			Lovable Cloud; not owner-configurable.
AU-5	Response to Audit Logging Process Failures			X	Owner responsibility; no alerting (gap).
AU-6	Audit Record Review, Analysis, and Reporting			X	Owner responsibility; no scheduled review (gap).
AU-8	Time Stamps	X			Lovable Cloud platform time source.
AU-9	Protection of Audit Information		X		Provider: Lovable Cloud (platform protection). Owner applies RLS to application tables.
AU-11	Audit Record Retention		X		Provider: Lovable Cloud (platform log retention). Owner runs the 90-day application purge.
AU-12	Audit Record Generation		X		Provider: Lovable Cloud (platform log generation). Owner generates application event records.
CA-1	Policy and Procedures			X	Customer-authored CA policy (cta-policies.md).
CA-2	Control Assessments			X	Owner self-assessment (this SSP).
CA-3	Information Exchange			X	Owner documents and authorizes interconnections.
CA-5	Plan of Action and Milestones			X	Owner-maintained gap register; no dated milestones (gap).
CA-6	Authorization			X	Owner is the accountable authorizing party.
CA-7	Continuous Monitoring			X	Owner responsibility; no monitoring strategy (gap).
CA-9	Internal System Connections		X		Provider: Lovable Cloud (internal transport). Owner authorizes internal data access via RLS.
CM-1	Policy and Procedures			X	Customer-authored CM policy (cta-policies.md).
CM-2	Baseline Configuration			X	Owner responsibility; no formal baseline document (gap).
CM-4	Impact Analyses			X	Owner responsibility; no formal impact analysis (gap).
CM-5	Access Restrictions for Change			X	Change restricted to Owner; multifactor authentication on all administrative provider accounts.
CM-6	Configuration Settings		X		Provider: Lovable Cloud (platform settings). Owner sets application security settings.
CM-7	Least Functionality			X	Owner limits exposed functionality.
CM-8	System Component Inventory			X	Owner maintains the inventory in this SSP.
CM-10	Software Usage Restrictions			X	Owner uses components within license terms.
CM-11	User-installed Software			X	No user-installed software is possible.
CP-1	Policy and Procedures			X	Customer-authored CP policy (cta-policies.md).
CP-2	Contingency Plan			X	Owner responsibility; no written plan (gap).
CP-3	Contingency Training			X	Not applicable: no workforce.
CP-4	Contingency Plan Testing			X	Owner responsibility; no test performed (gap).
CP-9	System Backup		X		Provider: Lovable Cloud (platform backups). Owner residual: independent backup and tested restore (gap).

CP-10	System Recovery and Reconstitution		X		Provider: Lovable Cloud (platform recovery). Owner residual: documented recovery procedure (gap).
IA-1	Policy and Procedures			X	Customer-authored IA policy (cta-policies.md).
IA-2	Identification and Authentication (Organizational Users)			X	Owner authenticates to consoles; multifactor authentication on all administrative provider accounts.
IA-4	Identifier Management		X		Provider: Lovable Cloud (Supabase Auth). Owner defines the email identifier scheme.
IA-5	Authenticator Management		X		Provider: Lovable Cloud (hashing and storage). Owner sets registration rules; 12-char minimum is client-side only (gap).
IA-6	Authentication Feedback		X		Provider: Lovable Cloud (Supabase feedback behavior). Owner uses masked input fields.
IA-7	Cryptographic Module Authentication	X			Lovable Cloud and Cloudflare cryptographic modules.
IA-8	Identification and Authentication (Non-organizational Users)		X		Provider: Lovable Cloud (Supabase Auth). Owner requires authentication and disables anonymous sign-in.
IA-11	Re-authentication			X	Owner-implemented idle timeouts.
IR-1	Policy and Procedures			X	Customer-authored IR policy (cta-policies.md).
IR-2	Incident Response Training			X	Not applicable: no workforce.
IR-4	Incident Handling			X	Owner responsibility; ad hoc only (gap).
IR-5	Incident Monitoring			X	Owner responsibility; no incident monitoring (gap).
IR-6	Incident Reporting			X	Owner responsibility; no reporting procedure (gap).
IR-7	Incident Response Assistance		X		Provider: provider support channels. Owner residual: no dedicated IR assistance (gap).
IR-8	Incident Response Plan			X	Owner responsibility; no written plan (gap).
MA-1	Policy and Procedures			X	Customer-authored MA policy (cta-policies.md).
MA-2	Controlled Maintenance		X		Provider: Lovable Cloud and Cloudflare (infrastructure maintenance). Owner maintains the application.
MA-4	Nonlocal Maintenance		X		Provider: provider consoles. Owner residual: multifactor authentication on all administrative provider accounts.
MA-5	Maintenance Personnel		X		Provider: provider staff maintain platforms. Owner is the sole application maintainer.
MP-1	Policy and Procedures			X	Customer-authored MP policy (cta-policies.md).
MP-2	Media Access	X			Lovable Cloud managed storage; no owner-held media.
MP-6	Media Sanitization	X			Lovable Cloud data-center media handling.
MP-7	Media Use			X	Not applicable: no removable media.
PE-1	Policy and Procedures			X	Customer-authored PE policy stating the inheritance position (cta-policies.md).
PE-2	Physical Access Authorizations	X			Lovable Cloud and Cloudflare data centers.
PE-3	Physical Access Control	X			Lovable Cloud and Cloudflare data centers.
PE-4	Access Control for Transmission	X			Provider hosting infrastructure.
PE-5	Access Control for Output Devices			X	Not applicable: no organization-controlled output devices.
PE-6	Monitoring Physical Access	X			Lovable Cloud and Cloudflare data centers.
PE-7	(Withdrawn)	X			Withdrawn in Rev 5; incorporated into PE-2 and PE-3.
PE-8	Visitor Access Records	X			Lovable Cloud and Cloudflare data centers.
PE-12	Emergency Lighting	X			Lovable Cloud and Cloudflare data centers.
PE-13	Fire Protection	X			Lovable Cloud and Cloudflare data centers.
PE-14	Environmental Controls	X			Lovable Cloud and Cloudflare data centers.
PE-15	Water Damage Protection	X			Lovable Cloud and Cloudflare data centers.
PE-16	Delivery and Removal	X			Lovable Cloud and Cloudflare data centers.
PL-1	Policy and Procedures			X	Customer-authored PL policy (cta-policies.md).
PL-2	System Security and Privacy Plans			X	Owner maintains this SSP.
PL-4	Rules of Behavior			X	Owner publishes the Terms of Service.
PL-10	Baseline Selection			X	Owner selected the LOW baseline.
PL-11	Baseline Tailoring			X	Owner tailored the baseline.
PS-1	Policy and Procedures			X	Customer-authored PS policy (cta-policies.md).
PS-2	Position Risk Designation			X	Not applicable: no positions.
PS-3	Personnel Screening			X	Not applicable: no workforce.
PS-4	Personnel Termination			X	Not applicable: no workforce.
PS-5	Personnel Transfer			X	Not applicable: no workforce.
PS-6	Access Agreements			X	Owner responsibility; collaborator agreement is owner-input.
PS-7	External Personnel Security	X			Providers vet their own staff.
PS-8	Personnel Sanctions			X	Not applicable: no workforce.
PS-9	Position Descriptions			X	Not applicable: no positions.
RA-1	Policy and Procedures			X	Customer-authored RA policy (cta-policies.md).
RA-2	Security Categorization			X	Owner-asserted LOW; no formal exercise (gap).
RA-3	Risk Assessment			X	Owner responsibility; informal only (gap).
RA-5	Vulnerability Monitoring and Scanning		X		Provider: Lovable Cloud and Cloudflare (platform patching). Owner residual: application scanning (gap) and the breached-password check.
RA-7	Risk Response			X	Owner responds ad hoc.
SA-1	Policy and Procedures			X	Customer-authored SA policy (cta-policies.md).
SA-2	Allocation of Resources			X	Owner funds the services.
SA-3	System Development Life Cycle			X	Owner-run informal lifecycle.

SA-4	Acquisition Process			X	Owner accepts provider standard terms.
SA-5	System Documentation			X	Owner maintains this SSP; provider docs referenced.
SA-8	Security and Privacy Engineering Principles			X	Owner applies engineering principles in the build.
SA-9	External System Services		X		Provider: external services. Owner residual: governs reliance under provider terms.
SA-22	Unsupported System Components		X		Provider: providers maintain supported services. Owner residual: dependency end-of-support tracking (gap).
SC-1	Policy and Procedures			X	Customer-authored SC policy (cta-policies.md).
SC-5	Denial-of-service Protection		X		Provider: Cloudflare (edge DoS). Owner residual: application usage cap.
SC-7	Boundary Protection		X		Provider: Cloudflare and Lovable Cloud (network edge). Owner residual: application route gating.
SC-8	Transmission Confidentiality and Integrity		X		Provider: Cloudflare (edge TLS). Owner residual: HTTPS to services.
SC-12	Cryptographic Key Establishment and Management		X		Provider: Cloudflare and Lovable Cloud (keys). Owner residual: secret store usage.
SC-13	Cryptographic Protection	X			Cloudflare and Lovable Cloud implementations.
SC-15	Collaborative Computing Devices and Applications			X	Not applicable: no system-controlled collaborative devices.
SC-20	Secure Name/Address Resolution Service (Authoritative Source)		X		Provider: Cloudflare (authoritative DNS). Owner residual: confirm and enable DNSSEC (owner-input).
SC-21	Secure Name/Address Resolution Service (Recursive or Caching Resolver)			X	Not applicable: no organization-operated resolver.
SC-22	Architecture and Provisioning for Name/Address Resolution Service	X			Cloudflare DNS infrastructure.
SC-28	Protection of Information at Rest		X		Provider: Lovable Cloud (encryption at rest). Owner residual: RLS.
SC-39	Process Isolation	X			Lovable Cloud and Cloudflare runtime isolation.
SI-1	Policy and Procedures			X	Customer-authored SI policy (cta-policies.md).
SI-2	Flaw Remediation		X		Provider: Lovable Cloud and Cloudflare (platform patching). Owner residual: application remediation.
SI-3	Malicious Code Protection		X		Provider: hosting infrastructure. Owner residual: text-only input, spam and suppression tracking.
SI-4	System Monitoring		X		Provider: Cloudflare (edge analytics). Owner residual: active monitoring and alerting (gap).
SI-5	Security Alerts, Advisories, and Directives		X		Provider: provider notifications. Owner residual: formal advisory process (gap).
SI-12	Information Management and Retention			X	Owner sets retention; chat and form schedule undocumented (gap).
SR-1	Policy and Procedures			X	Customer-authored SR policy (cta-policies.md).
SR-2	Supply Chain Risk Management Plan			X	Owner responsibility; no formal plan (gap).
SR-3	Supply Chain Controls and Processes		X		Provider: provider controls. Owner residual: keeps the dependency set small.
SR-5	Acquisition Strategies, Tools, and Methods			X	Owner selects known providers.
SR-8	Notification Agreements	X			Provider standard breach and incident terms.
SR-10	Inspection of Systems or Components	X			Owner has no direct access; relies on providers.
SR-11	Component Authenticity		X		Provider: providers and official channels. Owner residual: acquires via official channels.
SR-12	Component Disposal		X		Provider: Lovable Cloud and Cloudflare (physical disposal). Owner residual: logical cleanup (owner-input items).

4. Data Types and PII

The system collects and stores the following personal information: email address (account identifier), source IP address (captured from `x-forwarded-for` for authentication events), user chat content, and whatever users volunteer through the contact form (`contact_messages`) and the demographics form (`demographics_submissions`). This data meets the federal definition of personally identifiable information (PII). The impact level of the PII is assessed as LOW.

The system does not store cardholder data. Stripe hosts checkout off-site and the system records only plan status and expiration written back by `verify-paid-session`. The system does not knowingly collect Social Security numbers, financial account numbers, health information, or data from children.

5. Data Flows

1. **Web access.** User traffic reaches the Lovable-hosted frontend through the Cloudflare edge over TLS.
2. **Authentication.** The browser authenticates to Supabase Auth with email and password. The `log-auth-event` edge function writes a record to `auth_events` (event type and source IP from `x-forwarded-for`).
3. **Chat/AI.** The browser calls the `chat` edge function. For free-tier accounts the function checks `profiles.free_messages_used` against the 20-message lifetime cap before calling Anthropic. The Anthropic API key is held in edge-function secrets; the browser never calls Anthropic directly. The AI response returns through the edge function.
4. **Payment.** The browser is sent to Stripe hosted checkout. On completion, `verify-paid-session` matches the checkout to a Supabase account by email and writes `plan`, `plan_expires_at`, and `first_purchase_used`.
5. **Transactional email.** The system sends signup confirmation and magic-link recovery through Resend.
6. **Human handoff.** "Send to Human Support" forwards the conversation to the Proton support mailbox.
7. **Analytics.** The browser makes non-blocking calls to the `log-analytics` edge function (explicit CORS origin allowlist) which writes to first-party analytics tables. Cloudflare Analytics operates at the edge. No third-party analytics tooling is used.

6. Provider Responsibility Summary (Inherited Controls)

Many technical and physical controls are inherited from providers. Where a control below is marked Inherited or Partially Implemented, the provider is named and the inherited portion is separated from what the system does itself.

- **Lovable / Lovable Cloud (managed Supabase):** physical and environmental protection of the compute and database, hypervisor and process isolation, platform patching, database backups, TLS to the origin, and the Auth service. The owner cannot access the underlying Supabase project directly, which constrains what the owner can configure or independently verify.
- **Cloudflare:** edge TLS, DDoS protection, DNS integrity (DNSSEC where enabled), and network boundary protection at the edge.
- **Stripe:** PCI DSS compliant payment processing and cardholder data handling.
- **Anthropic:** security of the LLM inference service.
- **Resend:** transactional email delivery infrastructure.

---

7. Status Legend

- **Implemented:** the system performs this control today.
- **Partially Implemented:** the system performs part of this control; the remainder is a gap or is inherited.
- **Inherited:** the control is provided by a named provider and the owner relies on it.
- **Not Applicable:** the control does not apply to this system, with a stated reason.
- **Not Implemented (Gap):** the control is in the baseline, applies, and is not in place. It is listed here honestly and repeated in Known Gaps.

AC - Access Control

AC-1 - Policy and Procedures

Implementation Statement: A written access control policy exists in the CTA policy manual (cta-policies.md, AC - Access Control Policy). It defines purpose and scope, assigns all access control roles to the single owner as the designated official, states management commitment, coordination with the authentication and edge providers, and compliance monitoring, and sets a review cadence of at least annually and following any significant system change. The policy documents the access control practices the system actually follows: authenticated and gated access, disabled anonymous sign-in, server-side validation of paid access, Row Level Security restricting users to their own rows, and administrative access limited to the owner.
Evidence: cta-policies.md (AC - Access Control Policy); Supabase Auth configuration; RLS policies; `ChatAccessGate`.
Status: Implemented.

AC-2 - Account Management

Implementation Statement: End-user accounts are managed by Supabase Auth. Accounts are created through email/password signup, which fires a database trigger that creates the matching `profiles` row. A `user_roles` table holds role assignments separately from `profiles`. Administrative access to the platform (Lovable, Lovable Cloud backend view, Stripe, Cloudflare, Resend, Proton) belongs to the single owner. Two accounts currently exist in the user table, both belonging to the owner or a marketing collaborator. There is no documented account review cycle, and account disabling and removal rely on Supabase Auth and provider console actions rather than a written procedure.
Evidence: Supabase Auth; `profiles` table and signup trigger; `user_roles` table.
Status: Partially Implemented.

AC-3 - Access Enforcement

Implementation Statement: Access to application data is enforced by Postgres Row Level Security, which restricts each authenticated user to their own rows. Access to paid functionality is enforced by `ChatAccessGate` on the `/chat` and `/triage` routes, which grants access for an active non-expired plan, an account under the free-message cap, or a legacy paid token that is validated server-side by `validatePaidTokenWithServer()`. The free-tier message cap is enforced server-side in the `chat` edge function before the Anthropic call. A prior version of the access gate enforced paid access from `localStorage` alone and was remediated (Finding 2026-01). Legacy beta access codes, which previously accepted any code of the correct length, have been retired entirely, and EXECUTE on the SECURITY DEFINER database functions has been revoked from the `public`, `anon`, and `authenticated` roles so that only the `service_role` can call them (Findings 2026-02 and 2026-05).
Evidence: RLS policies; `ChatAccessGate`; `validatePaidTokenWithServer()`; `supabase/functions/chat/index.ts`; retired `validate-beta`; SECURITY DEFINER EXECUTE lockdown.
Status: Implemented.

AC-7 - Unsuccessful Logon Attempts

Implementation Statement: Failed logins are handled by Supabase Auth, which applies its own rate limiting to authentication endpoints. The application records `login_fail` events with source IP in `auth_events` through the `log-auth-event` edge function. The owner cannot configure a custom account lockout threshold or duration because Lovable Cloud does not expose those Supabase Auth settings; the lockout/throttling behavior is inherited from the platform.
Evidence: `log-auth-event` edge function; `auth_events` table; Supabase Auth rate limiting.
Status: Partially Implemented (throttling Inherited from Supabase; failure logging Implemented).

AC-8 - System Use Notification

Implementation Statement: The login and signup screens present a system-use notice reading "Authorized use only. Activity on this system is logged," with a link to the Terms of Service. This is a client-side display notice, which is the appropriate form for a consumer web application. Public Terms of Service and Privacy Policy pages remain live.
Evidence: System-use notice on `Login.tsx` and `Signup.tsx` linking to `/terms`; `/terms`, `/privacy`.
Status: Implemented (client-side display notice).

AC-14 - Permitted Actions Without Identification or Authentication

Implementation Statement: Unauthenticated users may view only public content: the homepage, `/pricing`, `/training`, `/privacy`, and `/terms`. All chat and troubleshooting functionality is gated behind authentication; anonymous sign-in is disabled. No privileged or data-modifying action is permitted without authentication.
Evidence: Public route set; `ChatAccessGate`; Supabase Auth with anonymous sign-in disabled.
Status: Implemented.

AC-17 - Remote Access

Implementation Statement: The system is a public web application; all user and administrative access is remote by nature and occurs over TLS. Administrative access to the management planes (Lovable, Cloudflare, Stripe, Resend, Proton) is over each provider's authenticated HTTPS console. There is no separate corporate network, VPN, or private management interface to secure.
Evidence: Cloudflare edge TLS; provider consoles; multifactor authentication on all administrative provider accounts.
Status: Implemented (application), with edge TLS Inherited from Cloudflare.

AC-18 - Wireless Access

Implementation Statement: The system operates no wireless networking. It is a cloud-hosted application with no owned facility, on-premises network, or wireless access points.
Evidence: Fully cloud-hosted architecture; no owned facility.
Status: Not Applicable (no organization-operated wireless).

AC-19 - Access Control for Mobile Devices

Implementation Statement: The system does not issue or manage mobile devices and operates no mobile device management. End users reach the responsive web application from their own devices, which are outside the boundary and outside the owner's control.
Evidence: No owned or managed mobile device fleet.
Status: Not Applicable (no organization-managed mobile devices).

AC-20 - Use of External Systems

Implementation Statement: The system integrates with external services for defined functions: Anthropic for inference, Stripe for payment, Resend for email, Cloudflare for edge and DNS, and Proton and Zoom for support and training. Each integration is scoped to its function. There is no written policy governing use of external systems; the connections and their data exchange are documented in Sections 2 and 5 of this plan.
Evidence: Section 2.3 and Section 5; edge-function integrations.
Status: Partially Implemented.

AC-22 - Publicly Accessible Content

Implementation Statement: Publicly accessible content is limited to the homepage, `/pricing`, `/training`, `/privacy`, and `/terms`. This content is authored and published by the single owner, so review and posting authority rest with one accountable person. No user-generated content is published to public pages.
Evidence: Public route set; single-owner publishing.
Status: Implemented.

AT - Awareness and Training

AT-1 - Policy and Procedures

Implementation Statement: A written awareness and training policy exists in the CTA policy manual (cta-policies.md, AT - Awareness and Training Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. Consistent with a single-operator business with no employees, the policy states that no formal workforce awareness or role-based training program is maintained and makes the owner responsible for maintaining their own security competence.
Evidence: cta-policies.md (AT - Awareness and Training Policy); single-operator business.
Status: Implemented.

AT-2 - Literacy Training and Awareness

Implementation Statement: There is no formal security awareness program because there are no employees. The owner is a practicing technician whose own security literacy is applied directly to the build (for example the HIBP breached-password check and the localStorage remediation described in Section 9). No structured, recurring awareness training is documented.
Evidence: Single-operator business; security practices in the codebase.
Status: Not Applicable (no workforce); owner competency evidenced in build.

AT-3 - Role-based Training

Implementation Statement: There are no defined organizational roles beyond the single owner, and therefore no role-based training program. The owner performs all roles.
Evidence: Single-operator business.
Status: Not Applicable (no workforce roles).

AT-4 - Training Records

Implementation Statement: No training records are maintained because no training program exists for a business with no employees.
Evidence: Single-operator business.
Status: Not Applicable (no workforce).

AU - Audit and Accountability

AU-1 - Policy and Procedures

Implementation Statement: A written audit and accountability policy exists in the CTA policy manual (cta-policies.md, AU - Audit and Accountability Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with the platform providers, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents the events the system logs, the 90-day authentication-event retention, and the protection of audit data, and it records honestly that alerting on logging failures and scheduled log review are not yet in place.
Evidence: cta-policies.md (AU - Audit and Accountability Policy); `log-auth-event`; `log-analytics`; `auth_events`.

Status: Implemented.

AU-2 - Event Logging

Implementation Statement: The system logs authentication events (`signup`, `login_success`, `login_fail`, `logout`) to the `auth_events` table with source IP. First-party analytics events are captured by the `log-analytics` edge function. The Lovable Cloud platform provides default logging for the database and edge functions. There is no documented, deliberated list of auditable events beyond what these mechanisms capture.
Evidence: `auth_events` table; `log-auth-event`; `log-analytics`; Lovable Cloud platform logs.
Status: Partially Implemented.

AU-3 - Content of Audit Records

Implementation Statement: Authentication records in `auth_events` capture event type, source IP (from `x-forwarded-for`), and timestamp, associated with the user. The content of platform-level logs is determined by Lovable Cloud and is not configurable by the owner.
Evidence: `auth_events` schema; `log-auth-event`.
Status: Partially Implemented (application records Implemented; platform log content Inherited).

AU-4 - Audit Log Storage Capacity

Implementation Statement: Audit log storage capacity for platform logs and the database is managed by Lovable Cloud and is not owner-configurable. Application authentication events are stored in Postgres and constrained by a 90-day retention purge (see AU-11), which bounds growth.
Evidence: Lovable Cloud platform; `auth_events` 90-day pg_cron purge.
Status: Inherited (platform capacity) with application-side bounding Implemented.

AU-5 - Response to Audit Logging Process Failures

Implementation Statement: The system sends a non-blocking alert email through Resend when the `log-auth-event` or `log-analytics` edge functions throw or fail to insert. Alerter failures are swallowed and logged so they never block the request. Client analytics calls remain non-blocking. There is no broader logging-pipeline health monitor beyond these edge-function alerts.
Evidence: `supabase/functions/_shared/security-alert.ts` (Resend alert helper); try/catch alerting in `log-auth-event` and `log-analytics`.
Status: Partially Implemented (edge-function failure alerting; no full pipeline monitor).

AU-6 - Audit Record Review, Analysis, and Reporting

Implementation Statement: Automated alerting surfaces one defined audit pattern: five or more `login_fail` events from a single IP within 15 minutes trigger an email alert, evaluated by the `count_recent_login_fails` RPC. Beyond this trigger, `auth_events` and analytics tables remain queryable and Cloudflare Analytics is available at the edge, but no scheduled, documented human review of audit records is performed.
Evidence: `count_recent_login_fails(ip, 15)` RPC; Resend alerting in `log-auth-event`; `auth_events`; Cloudflare Analytics.
Status: Partially Implemented (one automated review trigger; no scheduled human review).

AU-8 - Time Stamps

Implementation Statement: Time stamps for database records and platform logs are generated by the Lovable Cloud platform using server system time in UTC. The owner does not manage or configure the time source; it is inherited.
Evidence: Postgres timestamps; Lovable Cloud platform time.
Status: Inherited (Lovable Cloud / Supabase).

AU-9 - Protection of Audit Information

Implementation Statement: Audit event data in `auth_events` is protected against forgery at the database layer: INSERT is revoked from the `anon` and `authenticated` roles and a restrictive RLS insert-deny policy is in place, so only the `service_role` writes audit rows. The `log-auth-event` edge function derives `user_id` and `email` from the caller's Supabase JWT and the source IP from `x-forwarded-for`, ignoring any client-supplied identity; pre-authentication events accept only a syntactic email hint and are rate-limited. This closes the client-forgeable audit-log condition (Finding 2026-03). Platform-level log protection is inherited from Lovable Cloud, which the owner cannot reach directly.
Evidence: `REVOKE INSERT` on `auth_events` from `anon`/`authenticated`; RLS insert-deny; JWT-derived identity in `log-auth-event`; Lovable Cloud managed access model.
Status: Implemented (application) with platform protection Inherited.

AU-11 - Audit Record Retention

Implementation Statement: Authentication events in `auth_events` are retained for 90 days and then purged automatically by a `pg_cron` job. Retention of platform-level logs is governed by Lovable Cloud defaults and is not owner-configurable. No formal retention requirement has been derived from a records schedule.
Evidence: `auth_events` 90-day pg_cron purge; Lovable Cloud defaults.
Status: Implemented (application retention) with platform retention Inherited.

AU-12 - Audit Record Generation

Implementation Statement: The application generates authentication event records through `log-auth-event` and analytics records through `log-analytics`. The platform generates database and edge-function logs. Record generation is present for the events the system defines; there is no centralized audit generation across all components.
Evidence: `log-auth-event`; `log-analytics`; Lovable Cloud platform logs.
Status: Partially Implemented.

CA - Assessment, Authorization, and Monitoring

CA-1 - Policy and Procedures

Implementation Statement: A written assessment, authorization, and monitoring policy exists in the CTA policy manual (cta-policies.md, CA - Assessment, Authorization, and Monitoring Policy). It defines purpose and scope, designates the owner as both assessor and authorizing party, states management

commitment and compliance, and sets a review cadence of at least annually and following any significant system change. It documents self-assessment through this SSP, owner acceptance of residual risk, documentation of interconnections, and the gap register that serves as the plan of action.
Evidence: cta-policies.md (CA - Assessment, Authorization, and Monitoring Policy); this SSP.
Status: Implemented.

CA-2 - Control Assessments

Implementation Statement: No independent or formal control assessment has been performed. This self-authored control review is the only assessment. The finding and remediation in Section 9 represents an ad hoc self-assessment result rather than a scheduled assessment.
Evidence: This SSP; Section 9.
Status: Partially Implemented (self-assessment only).

CA-3 - Information Exchange

Implementation Statement: The system exchanges data with external services over authenticated, encrypted connections: Anthropic (chat content for inference), Stripe (payment, off-site), Resend (transactional email), Cloudflare (edge and DNS), Proton (human-support email), and Zoom (training). These interconnections are documented in Sections 2.3 and 5. There are no signed interconnection security agreements; the relationships are governed by each provider's standard terms of service.
Evidence: Section 2.3; Section 5; provider terms of service.
Status: Partially Implemented (connections documented; no formal agreements beyond provider ToS).

CA-5 - Plan of Action and Milestones

Implementation Statement: No formal POA&M is maintained. The Known Gaps and Owner Input Required section of this document enumerates open weaknesses and serves as an informal plan of action; it does not yet assign remediation dates or owners beyond the single operator.
Evidence: Known Gaps section of this SSP.
Status: Partially Implemented (gap register present; no dated milestones).

CA-6 - Authorization

Implementation Statement: This is a private commercial system with no external authorizing official. The owner is the accountable authorizing party and accepts the residual risk described in this document. There is no formal authorization decision record beyond this plan.
Evidence: This SSP; single-owner accountability.
Status: Partially Implemented (owner acceptance; no formal ATO process, which is not required for a private system).

CA-7 - Continuous Monitoring

Implementation Statement: Continuous monitoring is limited to Cloudflare Analytics at the edge, first-party analytics tables, and the `auth_events` record. There is no defined monitoring strategy, no metrics, no alerting, and no scheduled review. This is a gap.
Evidence: Cloudflare Analytics; `auth_events`; absence of a monitoring strategy.
Status: Not Implemented (Gap).

CA-9 - Internal System Connections

Implementation Statement: Internal connections are between the frontend, the edge functions, and the Postgres database inside the managed Lovable Cloud environment. These connections are established and secured by the platform. The application authorizes internal data access through Row Level Security. The owner cannot separately configure the platform's internal networking.
Evidence: RLS policies; Lovable Cloud managed environment.
Status: Partially Implemented (application authorization Implemented; internal transport Inherited).

CM - Configuration Management

CM-1 - Policy and Procedures

Implementation Statement: A written configuration management policy exists in the CTA policy manual (cta-policies.md, CM - Configuration Management Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. It documents change restriction to the owner, the security-relevant settings kept in a known-good state, and the component inventory, and it records that a versioned baseline document and a formal impact-analysis step are not yet in place.
Evidence: cta-policies.md (CM - Configuration Management Policy); Supabase Auth settings; redirect allowlist; RLS.
Status: Implemented.

CM-2 - Baseline Configuration

Implementation Statement: There is no documented configuration baseline. The effective baseline is the current state of the Lovable project, the edge functions, the database schema, and the Cloudflare and provider settings. The platform maintains the runtime configuration; the owner has not captured a formal, versioned baseline document.
Evidence: Lovable project state; edge functions; database schema.
Status: Not Implemented (Gap) as a formal baseline; the platform maintains runtime state.

CM-4 - Impact Analyses

Implementation Statement: Changes are made directly by the single owner in the Lovable editor. There is no formal security impact analysis step. The localStorage access-gate weakness in Section 9 was found and fixed reactively during review rather than through a documented pre-change analysis.
Evidence: Section 9; single-operator change process.
Status: Not Implemented (Gap).

CM-5 - Access Restrictions for Change

Implementation Statement: The ability to change the system is restricted to the single owner through authenticated access to the management consoles, with multifactor authentication enabled on all administrative provider accounts. Change access is inherently limited because there is exactly one authorized

person. Edge-function secrets, including the Anthropic API key, are held in the platform secret store rather than in client code.
Evidence: Multifactor authentication on all administrative provider accounts; edge-function secret store; single owner.
Status: Implemented.

CM-6 - Configuration Settings

Implementation Statement: Security-relevant application settings that the owner controls are configured: anonymous sign-in disabled, an 11-entry redirect URL allowlist with no open wildcards, CORS origin allowlist on `log-analytics`, and RLS enabled on application tables. Other platform settings (for example server-side password minimum length) are not exposed by Lovable Cloud and cannot be configured by the owner. See IA-5.
Evidence: Supabase Auth settings (More > Cloud > Users); redirect allowlist; `log-analytics` CORS allowlist; RLS.
Status: Partially Implemented.

CM-7 - Least Functionality

Implementation Statement: The application exposes only the functions needed for its service: public marketing pages and gated chat/triage. Anonymous sign-in is disabled, and route access is gated. The Anthropic key is confined to a server-side edge function. The legacy beta access-code path has been retired (the `validate-beta` function and its `beta_session` token type removed), reducing attack surface (Finding 2026-02). A Cloudflare Worker named `empty-disk-1010` exists with 0 invocations and its purpose is unconfirmed; leftover unused functions run counter to least functionality and it should be confirmed and removed if not needed.
Evidence: Route gating; disabled anonymous sign-in; retired `validate-beta` function; `empty-disk-1010` Worker (0 invocations, unconfirmed).
Status: Partially Implemented.

CM-8 - System Component Inventory

Implementation Statement: This document constitutes the system component inventory: frontend, edge functions, database tables, providers, domains, and external interconnections are enumerated in Section 2. Two items are unconfirmed: the seventh Cloudflare domain and the `empty-disk-1010` Worker. There is no automated inventory mechanism.
Evidence: Section 2 of this SSP.
Status: Partially Implemented.

CM-10 - Software Usage Restrictions

Implementation Statement: The system uses managed platforms and standard third-party services under their respective terms of service. There is no license-tracking process, but the components in use (Lovable, Supabase via Lovable Cloud, Cloudflare, Stripe, Anthropic, Resend) are commercial or open-source dependencies used within their licenses. No formal software usage restriction procedure is documented.
Evidence: Provider terms of service; Section 2.
Status: Partially Implemented.

CM-11 - User-installed Software

Implementation Statement: End users cannot install software into the system; it is a hosted web application with no user-side installation or plugin capability. The owner installs application dependencies through the Lovable build environment.
Evidence: Hosted web application architecture.
Status: Implemented (no user-installed software is possible).

CP - Contingency Planning

CP-1 - Policy and Procedures

Implementation Statement: A written contingency planning policy exists in the CTA policy manual (cta-policies.md, CP - Contingency Planning Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. It documents reliance on platform backups and recovery and records honestly that a written contingency plan, an independent backup, and a tested restore are not yet in place.
Evidence: cta-policies.md (CP - Contingency Planning Policy); Lovable Cloud Database view.
Status: Implemented.

CP-2 - Contingency Plan

Implementation Statement: No documented contingency plan exists. The system depends on the availability and recovery capabilities of Lovable Cloud and Cloudflare, which are inherited, but the owner has not written a plan describing recovery objectives, roles, or steps.
Evidence: Absence of a contingency plan; inherited platform availability.
Status: Not Implemented (Gap).

CP-3 - Contingency Training

Implementation Statement: No contingency training is conducted. There are no employees to train, and the single owner has no documented contingency procedure to train against.
Evidence: Single-operator business; no contingency plan.
Status: Not Applicable (no workforce) with an underlying plan gap.

CP-4 - Contingency Plan Testing

Implementation Statement: No contingency plan test has been performed because no contingency plan exists. Backup restoration has not been tested (see CP-9).
Evidence: Absence of a contingency plan; untested restore.
Status: Not Implemented (Gap).

CP-9 - System Backup

Implementation Statement: Database backups are provided by Lovable Cloud and are surfaced in the Lovable Cloud Database view. The owner runs no

independent backups and has not tested a restore, so recoverability is assumed but unverified.
Evidence: Lovable Cloud Database view (platform backups); no independent backup or tested restore.
Status: Inherited (platform backups) with owner verification a Gap.

CP-10 - System Recovery and Reconstitution

Implementation Statement: Recovery of the database and platform is inherited from Lovable Cloud. Reconstitution of the application would rely on the Lovable project and provider consoles. There is no documented recovery procedure or tested recovery time.
Evidence: Lovable Cloud platform recovery; absence of a documented procedure.
Status: Inherited (platform) with documentation and testing a Gap.

IA - Identification and Authentication

IA-1 - Policy and Procedures

Implementation Statement: A written identification and authentication policy exists in the CTA policy manual (cta-policies.md, IA - Identification and Authentication Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with the managed authentication service, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents email-and-password authentication, disabled anonymous sign-in, the registration password rules, magic-link recovery, administrative multifactor authentication on all provider accounts, and the client-side-only password length gap.
Evidence: cta-policies.md (IA - Identification and Authentication Policy); Supabase Auth; registration form.
Status: Implemented.

IA-2 - Identification and Authentication (Organizational Users)

Implementation Statement: The only organizational user is the owner. The owner authenticates to the management consoles with provider accounts, and multifactor authentication is enabled on all administrative provider accounts. Because the organization is one person, privileged access is inherently constrained to a single identity.
Evidence: Multifactor authentication on all administrative provider accounts; single-owner access.
Status: Implemented.

IA-4 - Identifier Management

Implementation Statement: User identifiers are email addresses managed by Supabase Auth, with the corresponding `profiles` row keyed to `auth.users` by the signup trigger. Identifiers are unique per account. Reuse and deactivation are handled by the Supabase Auth account lifecycle.
Evidence: Supabase Auth; `profiles` (id FK auth.users); signup trigger.
Status: Implemented.

IA-5 - Authenticator Management

Implementation Statement: End users authenticate with email and password managed by Supabase Auth. Registration is routed through the `secure-signup` edge function, which rejects any password under 12 characters and any password found in the Have I Been Pwned k-anonymity range before the auth user is created; the client-side check and confirm-password field remain as a first layer. Supabase's native `password_hibp_enabled` is also on, so the breached-password check applies on any signup path. Account recovery uses magic-link email through Resend. Residual: Lovable Cloud exposes no Supabase Auth "before user created" hook, so the raw `/auth/v1/signup` endpoint remains reachable with the anon key and is not subject to the 12-character minimum (HIBP still applies there natively). The length floor is therefore enforced through `secure-signup` but not on the raw endpoint (Finding 2026-04).
Evidence: `supabase/functions/secure-signup/index.ts` (server-side 12-char minimum and HIBP); Supabase `password_hibp_enabled`; Resend magic-link recovery; Supabase Auth password hashing.
Status: Partially Implemented (server-side enforcement via `secure-signup`; residual bypass on the raw Supabase signup endpoint).

IA-6 - Authentication Feedback

Implementation Statement: Password entry is obscured by standard masked input fields provided by the browser and the Supabase Auth UI flows. Authentication error feedback does not disclose whether an email exists in a way the owner controls; this behavior is inherited from Supabase Auth.
Evidence: Masked password fields; Supabase Auth flows.
Status: Implemented (application) with feedback behavior Inherited.

IA-7 - Cryptographic Module Authentication

Implementation Statement: Cryptographic operations for authentication (password hashing, token signing, TLS) are performed by Supabase Auth and Cloudflare using their cryptographic modules. The owner does not select or manage the cryptographic modules; this is fully inherited.
Evidence: Supabase Auth; Cloudflare TLS.
Status: Inherited (Supabase, Cloudflare).

IA-8 - Identification and Authentication (Non-organizational Users)

Implementation Statement: All end users are non-organizational users. Each is uniquely identified and authenticated through Supabase Auth with email and password before accessing gated functionality. Anonymous sign-in is disabled, so no gated action is taken by an unidentified user.
Evidence: Supabase Auth; anonymous sign-in disabled; `ChatAccessGate`.
Status: Implemented.

IA-11 - Re-authentication

Implementation Statement: Sessions end on inactivity, forcing re-authentication: a 30-minute idle sign-out on authenticated non-chat routes via `useIdleLogout`, and a 10-minute idle timeout with a 2-minute warning on the chat surface. There is no additional step-up re-authentication before specific sensitive actions beyond these timeouts.
Evidence: `useIdleLogout` hook; chat idle timeout.
Status: Implemented.

IR - Incident Response

IR-1 - Policy and Procedures

Implementation Statement: A written incident response policy exists in the CTA policy manual (cta-policies.md, IR - Incident Response Policy). It defines purpose and scope, designates the owner as the sole responder, states management commitment and compliance, and sets a review cadence of at least annually and following any incident. It assigns the owner responsibility to investigate, contain, correct, and decide on notification, references provider support channels, and records honestly that a detailed phased incident response plan and defined handling procedure remain outstanding (see IR-4 and IR-8).
Evidence: cta-policies.md (IR - Incident Response Policy); Section 9 finding.
Status: Implemented.

IR-2 - Incident Response Training

Implementation Statement: No incident response training is conducted. There are no employees, and no documented IR procedure exists to train against.
Evidence: Single-operator business; no IR plan.
Status: Not Applicable (no workforce) with an underlying plan gap.

IR-4 - Incident Handling

Implementation Statement: There is no formal incident handling process. The single documented incident, the localStorage access-gate weakness in Section 9, was detected during review and remediated the same day, which demonstrates an ad hoc detect-and-correct capability but not a defined handling procedure with containment, eradication, and recovery phases.
Evidence: Section 9, Findings and Remediation.
Status: Partially Implemented (ad hoc; no documented process).

IR-5 - Incident Monitoring

Implementation Statement: There is no dedicated incident monitoring. `auth_events`, first-party analytics, and Cloudflare Analytics provide raw signal, but no alerting or tracking of incidents is in place.
Evidence: `auth_events`; Cloudflare Analytics; no alerting.
Status: Not Implemented (Gap).

IR-6 - Incident Reporting

Implementation Statement: No formal internal or external incident reporting process exists. As a single-owner private business with no federal reporting obligation identified, reporting would be the owner's own judgment. No breach-notification procedure to affected users is documented.
Evidence: Single-operator business; absence of a reporting procedure.
Status: Not Implemented (Gap).

IR-7 - Incident Response Assistance

Implementation Statement: No incident response support resource or retainer exists. The owner would rely on provider support channels (Lovable, Cloudflare, Stripe) if an incident touched those platforms.
Evidence: Provider support channels; no dedicated IR assistance.
Status: Not Implemented (Gap) with provider support available.

IR-8 - Incident Response Plan

Implementation Statement: No written incident response plan exists. This is a gap.
Evidence: Absence of an IR plan.
Status: Not Implemented (Gap).

MA - Maintenance

MA-1 - Policy and Procedures

Implementation Statement: A written maintenance policy exists in the CTA policy manual (cta-policies.md, MA - Maintenance Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. The policy separates inherited infrastructure maintenance, performed by the providers, from application maintenance performed by the owner over authenticated consoles with multifactor authentication enabled on all administrative provider accounts.
Evidence: cta-policies.md (MA - Maintenance Policy); provider-managed platforms.
Status: Implemented.

MA-2 - Controlled Maintenance

Implementation Statement: Infrastructure maintenance (host patching, database engine updates, runtime maintenance) is performed by Lovable Cloud and Cloudflare on their schedules and is not controlled or scheduled by the owner. Application-level updates are made by the owner directly in the Lovable editor.
Evidence: Lovable Cloud and Cloudflare managed maintenance; Lovable editor for application changes.
Status: Inherited (platform maintenance) with application changes Implemented by the owner.

MA-4 - Nonlocal Maintenance

Implementation Statement: All maintenance is nonlocal by nature, performed remotely over authenticated, encrypted provider consoles. The owner's access to the management consoles is protected by multifactor authentication on all administrative provider accounts. Provider-side maintenance access is governed by the providers.
Evidence: Multifactor authentication on all administrative provider accounts; provider consoles over HTTPS.
Status: Implemented (owner access) with provider maintenance Inherited.

MA-5 - Maintenance Personnel

Implementation Statement: The only maintenance person for the application is the owner. Underlying platform maintenance personnel are employed and vetted by the providers and are outside the owner's control.
Evidence: Single owner; provider-employed platform staff.
Status: Implemented (owner) with provider personnel Inherited.

MP - Media Protection

MP-1 - Policy and Procedures

Implementation Statement: A written media protection policy exists in the CTA policy manual (cta-policies.md, MP - Media Protection Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. The policy states that the system uses no removable or owner-held media, that physical media protection is inherited from the managed backend provider, and that application data deletion is logical.
Evidence: cta-policies.md (MP - Media Protection Policy); cloud-only storage.
Status: Implemented.

MP-2 - Media Access

Implementation Statement: The system uses no removable or physical media. All data resides on managed cloud storage under Lovable Cloud, where physical media access is controlled by the provider and its data centers.
Evidence: Cloud-only storage; Lovable Cloud managed media.
Status: Inherited (Lovable Cloud) / Not Applicable to owner-held media.

MP-6 - Media Sanitization

Implementation Statement: Sanitization of physical storage media is performed by the cloud provider under its data-center decommissioning process. The owner holds no media to sanitize. Application data deletion is logical, through the database.
Evidence: Provider data-center media handling; logical deletion in Postgres.
Status: Inherited (Lovable Cloud) / Not Applicable to owner-held media.

MP-7 - Media Use

Implementation Statement: There is no organization-controlled removable media in use. The architecture provides no mechanism for it.
Evidence: Cloud-only architecture.
Status: Not Applicable (no removable media).

PE - Physical and Environmental Protection

The system is fully cloud-hosted and eBiz Market, LLC operates no data center or owned facility that houses the system. Physical and environmental controls for the compute, storage, and network are inherited from the underlying data-center operators used by Lovable Cloud and Cloudflare. The owner cannot inspect or configure these facilities and does not have provider audit reports on hand (owner-input-required if attestation is needed). The controls below are therefore inherited or not applicable, stated honestly rather than fabricated.

PE-1 - Policy and Procedures

Implementation Statement: A written physical and environmental protection policy exists in the CTA policy manual (cta-policies.md, PE - Physical and Environmental Protection Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. The policy states the inheritance position: the owner operates no facility and inherits all physical and environmental controls from the data-center operators used by the providers, with the owner's residual responsibility limited to identifying that inheritance accurately and obtaining provider attestations if required.
Evidence: cta-policies.md (PE - Physical and Environmental Protection Policy); no owned facility.
Status: Implemented.

PE-2 - Physical Access Authorizations

Implementation Statement: Physical access authorization to the hosting facilities is managed by the data-center operators under Lovable Cloud and Cloudflare. The owner authorizes no physical access.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-3 - Physical Access Control

Implementation Statement: Physical access control at the hosting facilities is provided by the data-center operators. The owner controls no physical entry points.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-4 - Access Control for Transmission

Implementation Statement: Physical protection of transmission lines within the hosting infrastructure is handled by the providers. Logical transmission protection is addressed under SC-8.
Evidence: Provider infrastructure; see SC-8.
Status: Inherited.

PE-5 - Access Control for Output Devices

Implementation Statement: There are no organization-controlled physical output devices. Output is delivered digitally to users over the web.
Evidence: No owned output devices.
Status: Not Applicable.

PE-6 - Monitoring Physical Access

Implementation Statement: Monitoring of physical access to the facilities is performed by the data-center operators. The owner performs no physical access monitoring.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-7 - (Withdrawn)

Implementation Statement: PE-7 (Visitor Control) is withdrawn in NIST SP 800-53 Rev 5 and incorporated into PE-2 and PE-3. No separate statement applies.
Evidence: NIST SP 800-53 Rev 5 control catalog.
Status: Not Applicable (withdrawn).

PE-8 - Visitor Access Records

Implementation Statement: Visitor access records for the hosting facilities are maintained by the data-center operators. The owner maintains no facility and no visitor records.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-12 - Emergency Lighting

Implementation Statement: Emergency lighting in the hosting facilities is provided by the data-center operators.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-13 - Fire Protection

Implementation Statement: Fire detection and suppression in the hosting facilities are provided by the data-center operators.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-14 - Environmental Controls

Implementation Statement: Temperature, humidity, and related environmental controls in the hosting facilities are provided by the data-center operators.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-15 - Water Damage Protection

Implementation Statement: Water damage protection in the hosting facilities is provided by the data-center operators.
Evidence: Provider-managed data centers.
Status: Inherited.

PE-16 - Delivery and Removal

Implementation Statement: Delivery and removal of hardware at the hosting facilities are controlled by the data-center operators. The owner delivers or removes no system hardware.
Evidence: Provider-managed data centers.
Status: Inherited.

PL - Planning

PL-1 - Policy and Procedures

Implementation Statement: A written security planning policy exists in the CTA policy manual (cta-policies.md, PL - Planning Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. It documents maintenance of this SSP, selection and tailoring of the LOW baseline, and publication of end-user rules of behavior as the Terms of Service.
Evidence: cta-policies.md (PL - Planning Policy); this SSP; `/terms`.
Status: Implemented.

PL-2 - System Security and Privacy Plans

Implementation Statement: This document is the system security plan. It describes the boundary, data types and PII, data flows, and control implementation for the LOW baseline. A separate, formal privacy plan is not maintained, though a public Privacy Policy is live on the site.
Evidence: This SSP; `/privacy`.
Status: Implemented (security plan) with a formal privacy plan a partial gap.

PL-4 - Rules of Behavior

Implementation Statement: Public Terms of Service establish rules of behavior for end users, and users accept them as a condition of use. There are no separate internal rules of behavior because there are no employees beyond the owner.
Evidence: `/terms`.
Status: Implemented for end users; Not Applicable for internal staff.

PL-10 - Baseline Selection

Implementation Statement: The owner selected the NIST 800-53 Rev 5 LOW baseline as the applicable control set for this system, consistent with the LOW security categorization in Section 1. This document reflects that selection.
Evidence: Section 1; this SSP.
Status: Implemented.

PL-11 - Baseline Tailoring

Implementation Statement: The LOW baseline is tailored to the system in this document: controls that do not apply to a single-operator, fully cloud-hosted business (for example wireless, mobile device, and most physical controls) are marked Not Applicable or Inherited with stated reasons, and single-operator realities are reflected in the Personnel and Awareness families. Tailoring decisions are stated per control rather than in a separate register.
Evidence: Per-control Status and rationale throughout this SSP.
Status: Implemented.

PS - Personnel Security

eBiz Market, LLC has one owner-operator and no employees, contractors, or staff. The Personnel Security family is written to that reality. No org chart, hiring process, or screening program is invented.

PS-1 - Policy and Procedures

Implementation Statement: A written personnel security policy exists in the CTA policy manual (cta-policies.md, PS - Personnel Security Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and whenever a person other than the owner is granted access. The policy states the single-operator reality (no positions, screening, termination, transfer, or sanctions processes) and assigns the owner responsibility for any collaborator access agreement.
Evidence: cta-policies.md (PS - Personnel Security Policy); single-operator business.
Status: Implemented.

PS-2 - Position Risk Designation

Implementation Statement: There are no positions to designate. The owner holds all responsibility.
Evidence: Single-operator business.
Status: Not Applicable (no positions).

PS-3 - Personnel Screening

Implementation Statement: There is no personnel to screen. The owner is the sole principal of the LLC.
Evidence: Single-operator business.
Status: Not Applicable (no workforce).

PS-4 - Personnel Termination

Implementation Statement: There is no personnel termination process because there are no employees. Access removal for the owner is not applicable while the owner runs the business.
Evidence: Single-operator business.
Status: Not Applicable (no workforce).

PS-5 - Personnel Transfer

Implementation Statement: There are no personnel transfers.
Evidence: Single-operator business.
Status: Not Applicable (no workforce).

PS-6 - Access Agreements

Implementation Statement: No internal access agreements are needed for a single owner. A marketing collaborator holds one of the two existing accounts; whether a written access or confidentiality agreement covers that collaborator is owner-input-required.
Evidence: Two accounts (owner and marketing collaborator); collaborator agreement status unconfirmed.
Status: Partially Implemented / Owner Input Required.

PS-7 - External Personnel Security

Implementation Statement: External providers (Lovable, Cloudflare, Stripe, Anthropic, Resend, Proton, Zoom) employ and manage their own personnel under their own security programs. The owner relies on provider terms and does not separately vet provider staff.
Evidence: Provider terms of service.
Status: Inherited (providers).

PS-8 - Personnel Sanctions

Implementation Statement: There is no sanctions process because there are no employees.
Evidence: Single-operator business.
Status: Not Applicable (no workforce).

PS-9 - Position Descriptions

Implementation Statement: There are no position descriptions to maintain. The owner performs all functions.
Evidence: Single-operator business.
Status: Not Applicable (no positions).

RA - Risk Assessment

RA-1 - Policy and Procedures

Implementation Statement: A written risk assessment policy exists in the CTA policy manual (cta-policies.md, RA - Risk Assessment Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment and compliance, and sets a review cadence of at least annually and following any significant system change. It documents the LOW categorization, ad hoc risk response, and the breached-password check, and it

records that a formal categorization exercise, a formal risk assessment, and owner-run vulnerability scanning are not yet in place.
Evidence: cta-policies.md (RA - Risk Assessment Policy); Section 1 categorization; HIBP check.
Status: Implemented.

RA-2 - Security Categorization

Implementation Statement: The system is categorized LOW for confidentiality, integrity, and availability, as stated in Section 1. This is an owner assertion based on the nature of the data and service; it has not been produced through a formal, documented categorization exercise mapped to NIST SP 800-60 information types.
Evidence: Section 1 categorization.
Status: Partially Implemented (asserted, not formally documented).

RA-3 - Risk Assessment

Implementation Statement: No formal, documented risk assessment has been performed. This control review surfaces specific risks (client-side-only password length enforcement, no independent backups, no monitoring or incident response), but they are captured as gaps rather than through a structured risk assessment with likelihood and impact ratings.
Evidence: Known Gaps section; Section 9.
Status: Partially Implemented (informal; no formal assessment).

RA-5 - Vulnerability Monitoring and Scanning

Implementation Statement: Dependency vulnerability scanning is in place through the Lovable security scanner, which enumerates third-party package vulnerabilities. A scan on 2026-07-27 found 13 known vulnerabilities; remediation reduced these to 6 by upgrading `@supabase/supabase-js` and `react-router`/`react-router-dom` and applying npm overrides for `lodash` and `ws`. The remaining 6 are transitive vulnerabilities with no patched upstream version available (recharts-bundled `lodash`; `@lovable.dev/mcp-js` build tooling) and are accepted as monitored residuals with low real-world exploitability (Finding 2026-07). The registration flow also includes a HIBP breached-password check. Underlying platform vulnerability management is inherited from Lovable Cloud and Cloudflare. There is no owner-run application penetration or dynamic scan beyond dependency scanning.
Evidence: Lovable dependency scan (2026-07-27, 13 to 6); package upgrades and npm overrides; HIBP check; provider-managed platform patching.
Status: Partially Implemented (dependency scanning and remediation in place; monitored residuals with no upstream fix; no application dynamic scan).

RA-7 - Risk Response

Implementation Statement: Risk response is active but not yet a standing, calendared process. Each documented finding in Section 9, including the 2026-07-27 security-scan batch, was responded to by same-day remediation with a recorded disposition, and residual risks that have no available fix (for example the raw-endpoint password length and the monitored dependency CVEs) are accepted and stated explicitly. Remaining open risks are listed in Known Gaps without assigned remediation dates.
Evidence: Section 9 Findings and Remediation Log; Known Gaps section.
Status: Partially Implemented (documented dispositions; no dated remediation plan).

SA - System and Services Acquisition

SA-1 - Policy and Procedures

Implementation Statement: A written system and services acquisition policy exists in the CTA policy manual (cta-policies.md, SA - System and Services Acquisition Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with providers, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents resource allocation, acquisition under provider terms, the engineering principles applied in the build, and the informal-lifecycle and dependency-tracking gaps.
Evidence: cta-policies.md (SA - System and Services Acquisition Policy); provider subscriptions.
Status: Implemented.

SA-2 - Allocation of Resources

Implementation Statement: The owner allocates the funds for the platform and service subscriptions (Lovable, Cloudflare, Stripe, Anthropic, Resend, Proton, Zoom) that the system depends on. There is no formal resource-allocation process beyond the owner's budgeting.
Evidence: Active provider subscriptions.
Status: Implemented (informally, by the owner).

SA-3 - System Development Life Cycle

Implementation Statement: Development is performed by the owner in the Lovable environment. The lifecycle is informal and iterative: build, review, remediate (as shown by the Section 9 finding). There is no documented SDLC with defined phases and security gates.
Evidence: Lovable build environment; Section 9.
Status: Partially Implemented (informal lifecycle).

SA-4 - Acquisition Process

Implementation Statement: Services are acquired under each provider's standard commercial terms. Security expectations are those set in the providers' terms and documentation; the owner does not negotiate custom security requirements into contracts.
Evidence: Provider terms of service.
Status: Partially Implemented (standard terms accepted).

SA-5 - System Documentation

Implementation Statement: System documentation consists of this SSP, the application source in the Lovable project, and provider documentation. There is no separate administrator or user security guide beyond the public Terms and Privacy pages.
Evidence: This SSP; Lovable project; provider docs; `/terms`, `/privacy`.
Status: Partially Implemented.

SA-8 - Security and Privacy Engineering Principles

Implementation Statement: Several sound engineering principles are applied in the build: server-side enforcement of the free-tier cap before the Anthropic call, the Anthropic key confined to a server-side edge function, Row Level Security limiting users to their own rows, a CORS origin allowlist rather than a wildcard, a redirect URL allowlist, disabled anonymous sign-in, and a breached-password check. The localStorage remediation in Section 9 moved a trust decision from the client to the server, applying least-trust to the client. These are applied in practice rather than governed by a written principles document.
Evidence: `chat` edge function; edge-function secrets; RLS; `log-analytics` CORS allowlist; redirect allowlist; `validatePaidTokenWithServer()`.
Status: Implemented (in practice).

SA-9 - External System Services

Implementation Statement: The system relies on external services (Anthropic, Stripe, Resend, Cloudflare, Proton, Zoom) for defined functions. Their roles and data exchange are documented in Sections 2.3 and 5. Reliance is governed by provider terms of service rather than by owner-defined security service-level agreements.
Evidence: Section 2.3; Section 5; provider terms.
Status: Partially Implemented.

SA-22 - Unsupported System Components

Implementation Statement: The core platforms in use (Lovable, Supabase via Lovable Cloud, Cloudflare, Stripe, Anthropic API with claude-sonnet-4-5, Resend) are current, vendor-supported services. Application dependency versions and their known vulnerabilities are now enumerated by the Lovable dependency scanner, giving visibility into outdated or unsupported components; a scan-driven remediation was performed on 2026-07-27. There is still no formal end-of-support calendar tracking each dependency.
Evidence: Lovable dependency scanner (version and vulnerability enumeration); 2026-07-27 remediation; current provider services.
Status: Partially Implemented.

SC - System and Communications Protection

SC-1 - Policy and Procedures

Implementation Statement: A written system and communications protection policy exists in the CTA policy manual (cta-policies.md, SC - System and Communications Protection Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with the edge and backend providers, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents encrypted transport, edge denial-of-service protection, the application-layer boundary settings, encryption at rest, and inherited cryptography.
Evidence: cta-policies.md (SC - System and Communications Protection Policy); Cloudflare edge TLS; RLS; edge-function secret store.
Status: Implemented.

SC-5 - Denial-of-service Protection

Implementation Statement: Denial-of-service protection is provided at the edge by Cloudflare, which fronts the primary domain. The application adds a server-side free-tier message cap that bounds per-account use of the paid Anthropic call, plus per-IP rate limits on sensitive endpoints: the magic-token validation endpoint (10 requests per minute per IP, returning HTTP 429) and the contact endpoint (3 per minute per IP). These application rate limits are per edge-function instance rather than distributed, so they blunt brute force and abuse but are not a distributed limiter.
Evidence: Cloudflare edge; `chat` edge-function message cap; `validate-magic-token` (10/min/IP); `send-contact` (3/min/IP).
Status: Inherited (Cloudflare) with application-side usage cap and per-IP endpoint rate limits Implemented.

SC-7 - Boundary Protection

Implementation Statement: The network boundary is enforced at the Cloudflare edge and by the managed Lovable Cloud environment. Application boundary protection is implemented through route gating (`ChatAccessGate`), disabled anonymous sign-in, the CORS origin allowlist on `log-analytics`, the redirect URL allowlist, and server-side validation of paid access. The owner cannot configure lower-level network boundary settings inside Lovable Cloud.
Evidence: Cloudflare edge; `ChatAccessGate`; `log-analytics` CORS allowlist; redirect allowlist; `validatePaidTokenWithServer()`.
Status: Partially Implemented (application boundary Implemented; network edge Inherited).

SC-8 - Transmission Confidentiality and Integrity

Implementation Statement: All traffic to the site is served over TLS terminated at the Cloudflare edge, and connections to external services (Anthropic, Stripe, Resend, Supabase Auth) use HTTPS. The owner relies on Cloudflare and the providers for cipher configuration and certificate management.
Evidence: Cloudflare edge TLS; HTTPS to all external services.
Status: Implemented, with TLS configuration Inherited from Cloudflare and providers.

SC-12 - Cryptographic Key Establishment and Management

Implementation Statement: Cryptographic keys for TLS, token signing, and password hashing are established and managed by Cloudflare and Supabase. Application secrets, including the Anthropic API key, are stored in the Lovable Cloud edge-function secret store rather than in code. The owner does not operate a key management system of their own.
Evidence: Cloudflare and Supabase key management; edge-function secret store.
Status: Inherited (Cloudflare, Supabase) with application secret storage Implemented.

SC-13 - Cryptographic Protection

Implementation Statement: Cryptographic protection in transit (TLS) and for stored credentials (Supabase password hashing) uses the providers' cryptographic implementations. The owner does not select algorithms; these are inherited.
Evidence: Cloudflare TLS; Supabase Auth hashing.
Status: Inherited (Cloudflare, Supabase).

SC-15 - Collaborative Computing Devices and Applications

Implementation Statement: The system operates no collaborative computing devices such as cameras or microphones. The human handoff uses email, and training is delivered over Zoom, which is external and user-initiated; the system activates no local collaborative devices.
Evidence: Email handoff; Zoom (external); no in-system collaborative devices.
Status: Not Applicable (no system-controlled collaborative computing devices).

SC-20 - Secure Name/Address Resolution Service (Authoritative Source)

Implementation Statement: Authoritative DNS for the primary domain is provided by Cloudflare, which supports DNSSEC. Whether DNSSEC is enabled for `communitytechaid.ai` is owner-input-required. The owner relies on Cloudflare as the authoritative source.
Evidence: Cloudflare authoritative DNS; DNSSEC status unconfirmed.
Status: Inherited (Cloudflare); DNSSEC enablement Owner Input Required.

SC-21 - Secure Name/Address Resolution Service (Recursive or Caching Resolver)

Implementation Statement: Recursive and caching resolution for end users occurs on their own networks and resolvers, outside the boundary. The system operates no recursive resolver.
Evidence: No system-operated resolver.
Status: Not Applicable (no organization-operated recursive resolver).

SC-22 - Architecture and Provisioning for Name/Address Resolution Service

Implementation Statement: DNS architecture and provisioning are handled by Cloudflare across its distributed, fault-tolerant network. The owner does not architect or provision DNS infrastructure.
Evidence: Cloudflare DNS infrastructure.
Status: Inherited (Cloudflare).

SC-28 - Protection of Information at Rest

Implementation Statement: Application data at rest resides in the managed Lovable Cloud Postgres database, where encryption at rest is provided by the platform. Row Level Security additionally restricts logical access to each user's own rows. The owner cannot configure or independently verify the underlying encryption because there is no direct database access.
Evidence: Lovable Cloud managed Postgres; RLS policies.
Status: Inherited (Lovable Cloud) with application-layer RLS Implemented.

SC-39 - Process Isolation

Implementation Statement: Process and tenant isolation is provided by the Lovable Cloud and Cloudflare platforms. Each edge-function invocation and the database run within the provider's isolation model. The owner does not manage process isolation.
Evidence: Lovable Cloud and Cloudflare runtime isolation.
Status: Inherited (Lovable Cloud, Cloudflare).

SI - System and Information Integrity

SI-1 - Policy and Procedures

Implementation Statement: A written system and information integrity policy exists in the CTA policy manual (cta-policies.md, SI - System and Information Integrity Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with providers, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents owner flaw remediation, inherited platform patching, text-only input with spam and suppression tracking, and the 90-day authentication-event retention, and it records the monitoring, advisory-process, and retention-schedule gaps.
Evidence: cta-policies.md (SI - System and Information Integrity Policy); `spam_attempts`; `suppression_list`; `auth_events`.
Status: Implemented.

SI-2 - Flaw Remediation

Implementation Statement: Platform and infrastructure flaws are remediated by Lovable Cloud and Cloudflare. Application flaws are remediated by the owner directly in the Lovable editor, typically the same day they are found; the Remediation Log in Section 9 records a batch of scan-driven fixes on 2026-07-27 (beta-code retirement, audit-log hardening, server-side password enforcement, SECURITY DEFINER lockdown, rate limits, retention, and dependency remediation). Dependency vulnerabilities are now enumerated by the Lovable dependency scanner. There is still no fixed, scheduled patch cadence.
Evidence: Provider patching; Section 9 Remediation Log 2026-07-27; Lovable editor; Lovable dependency scanner.
Status: Partially Implemented (platform Inherited; active but not-yet-scheduled application remediation).

SI-3 - Malicious Code Protection

Implementation Statement: The application accepts text input, not file uploads or executable content, which limits malicious-code exposure. The system tracks `spam_attempts` and maintains a `suppression_list`. Endpoint and infrastructure malware protection is inherited from the providers. There is no dedicated anti-malware scanning operated by the owner.
Evidence: `spam_attempts` table; `suppression_list`; text-only input; provider infrastructure.
Status: Partially Implemented.

SI-4 - System Monitoring

Implementation Statement: Monitoring combines Cloudflare Analytics at the edge, first-party analytics tables, and the `auth_events` record with defined alerting: a non-blocking Resend email alert fires on five or more `login_fail` events from one IP within 15 minutes and on `log-auth-event` or `log-analytics` edge-function errors. There is no SIEM and no scheduled human review, but the system is no longer silent on these defined triggers.
Evidence: Cloudflare Analytics; `auth_events`; `count_recent_login_fails` RPC; `_shared/security-alert.ts` Resend alerts.
Status: Partially Implemented (defined alert triggers; no SIEM or scheduled review).

SI-5 - Security Alerts, Advisories, and Directives

Implementation Statement: The owner receives security advisories informally through provider notifications (Lovable, Cloudflare, Stripe). There is no formal process to receive, evaluate, and act on security alerts and directives.
Evidence: Provider notifications; no formal advisory process.
Status: Partially Implemented (informal).

SI-12 - Information Management and Retention

Implementation Statement: Retention and disposal are scheduled in the database by daily `pg_cron` jobs running security-definer purge functions: `auth_events` at 90 days, and `chat_sessions`, `contact_messages`, and `demographics_submissions` at 180 days. Retention windows are now defined and enforced for every owner-controlled personal-data table (Finding 2026-06). A public Privacy Policy is live.
Evidence: Daily `pg_cron` purge jobs: `auth_events` 90d, `chat_sessions`/`contact_messages`/`demographics_submissions` 180d; `/privacy`.
Status: Implemented.

SR - Supply Chain Risk Management

SR-1 - Policy and Procedures

Implementation Statement: A written supply chain risk management policy exists in the CTA policy manual (cta-policies.md, SR - Supply Chain Risk Management Policy). It defines purpose and scope, designates the owner as the responsible official, states management commitment, coordination with providers, and compliance, and sets a review cadence of at least annually and following any significant system change. It documents sourcing from a small set of established providers through official channels, reliance on provider notification terms, and logical component disposal, and it records the supply-chain-plan and inspection gaps.
Evidence: cta-policies.md (SR - Supply Chain Risk Management Policy); Section 2 component set.
Status: Implemented.

SR-2 - Supply Chain Risk Management Plan

Implementation Statement: No formal supply chain risk management plan exists. The dependency set is documented in Section 2, but risks in that supply chain are not formally analyzed or planned for.
Evidence: Section 2; absence of an SCRM plan.
Status: Not Implemented (Gap).

SR-3 - Supply Chain Controls and Processes

Implementation Statement: The system depends on a small set of established providers (Lovable, Supabase via Lovable Cloud, Cloudflare, Stripe, Anthropic, Resend). Supply chain controls are effectively those the providers apply; the owner applies no additional supply chain process.
Evidence: Provider set in Section 2.
Status: Partially Implemented (Inherited from providers).

SR-5 - Acquisition Strategies, Tools, and Methods

Implementation Statement: Acquisition is limited to subscribing to commercial managed services under their standard terms. There is no formal strategy to manage supply chain risk in acquisition beyond choosing known vendors.
Evidence: Provider subscriptions and terms.
Status: Partially Implemented.

SR-8 - Notification Agreements

Implementation Statement: The owner relies on providers' standard breach and incident notification practices as stated in their terms of service. There are no custom notification agreements in place.
Evidence: Provider terms of service.
Status: Inherited (provider standard terms).

SR-10 - Inspection of Systems or Components

Implementation Statement: The owner cannot inspect the underlying managed components (no direct Supabase project access, no service role key, no database URL) and performs no independent component inspection. Integrity of the managed platform is relied upon from the providers.
Evidence: Constrained Lovable Cloud access; no direct component access.
Status: Inherited / Not Applicable to owner inspection.

SR-11 - Component Authenticity

Implementation Statement: Component authenticity for the platform and services is assured by acquiring directly from the authentic providers (Lovable, Cloudflare, Stripe, Anthropic, Resend) through their official channels. The owner performs no separate authenticity verification of software components.
Evidence: Direct provider relationships through official channels.
Status: Partially Implemented (Inherited).

SR-12 - Component Disposal

Implementation Statement: Disposal of physical components is handled by the providers under their data-center processes. Application data disposal is logical, through the database. The owner disposes of no physical components. The `empty-disk-1010` Cloudflare Worker and the non-primary domains are candidate items for logical cleanup, pending confirmation.
Evidence: Provider data-center disposal; logical data deletion; `empty-disk-1010` (unconfirmed).
Status: Inherited (physical) with logical cleanup items Owner Input Required.

---

8. Control Coverage Summary

This document addresses the enumerated LOW baseline base controls across 17 families: AC (11), AT (4), AU (10), CA (7), CM (9), CP (6), IA (8), IR (7), MA (4), MP (4), PE (13 incl. withdrawn PE-7), PL (5), PS (9), RA (5), SA (8), SC (12), SI (6), SR (8). Physical (PE) and several communications (SC) controls are inherited from Lovable Cloud and Cloudflare; Personnel (PS) and Awareness (AT) controls are largely Not Applicable to a single-operator business; the family policy and procedure (-1) controls are implemented through the CTA policy manual (cta-policies.md); and incident response, contingency planning, and risk assessment remain the largest cluster of genuine technical gaps. Those gaps are consolidated below.

---

9. Findings and Remediation

Finding 2026-01: Client-trusted paid access gate (remediated)

Weakness. An earlier version of the chat access gate used a hook, `usePaidAccess.ts`, that returned an authorized result based solely on two `localStorage` values, `cta_paid_access` and `cta_paid_access_expiry`, with no server-side verification. Because `localStorage` is fully client-controlled, anyone could set those keys in browser devtools and obtain unlimited paid access. This is a broken access control condition: a trust decision about authorization was made entirely on the client.

Detection. The weakness was identified by the owner during a security review of the access control path.

Remediation. The access decision was moved server-side. `ChatAccessGate` now routes the legacy-token case through `validatePaidTokenWithServer()`, so genuine legacy tokens are validated by the server while forged `localStorage` values no longer grant access. Active plan and free-tier checks are likewise enforced server-side, with the free-tier cap checked in the `chat` edge function before the Anthropic call. Remediation was completed the same day the weakness was found.

Control mapping. AC-3 (Access Enforcement), SA-8 (Security and Privacy Engineering Principles), SI-2 (Flaw Remediation), RA-7 (Risk Response).

Residual note. This was a self-identified, self-remediated finding. It is included because a documented detect-and-correct cycle is stronger evidence of a working security practice than an unblemished claim of full coverage.

Remediation Log 2026-07-27

A deep security scan on 2026-07-27 surfaced additional findings, each remediated the same day. This log records them and their control mappings.

Finding 2026-02: Beta access code accepted any code of the correct length (Critical). The legacy beta access-code check validated only the length of the submitted code, so any string of the right length granted access. Because access is now a free-tier-to-paid model, the beta path was obsolete. Remediation retired it entirely: the `validate-beta` edge function and its config were deleted and the `beta_session` token type was removed. Control mapping: AC-3, CM-7, SI-2.

Finding 2026-03: Audit log entries forgeable by clients (Warning). The `auth_events` table accepted client-written rows, allowing forged audit entries. Remediation revoked INSERT from the `anon` and `authenticated` roles, added a restrictive RLS insert-deny so only the `service_role` writes, and changed `log-auth-event` to derive identity from the caller's JWT and the IP server-side. Pre-authentication events accept only a syntactic email hint and are rate-limited to 20 per minute per IP. Control mapping: AU-9, SI-2.

Finding 2026-04: Password length enforced client-side only (carried from the prior review). Remediation added the `secure-signup` edge function, which enforces the 12-character minimum and a HIBP check server-side before the auth user is created. Residual: the raw `/auth/v1/signup` endpoint is not covered by the length rule because Lovable Cloud exposes no "before user created" hook; HIBP still applies there natively. Control mapping: IA-5.

Finding 2026-05: SECURITY DEFINER functions executable by public roles (Warning). EXECUTE on the security-definer functions (`count_recent_login_fails`, the retention purge functions, `prevent_spam_flooding`, `handle_new_user`, `set_updated_at`) was revoked from `public`, `anon`, and `authenticated` and granted only to `service_role`. `has_role` is retained for `authenticated` because RLS policies call it inline as the signed-in user. Control mapping: AC-3, CM-6, least-privilege.

Finding 2026-06: Missing rate limits and data-retention schedules (hardening). Per-IP rate limits were added to the magic-token endpoint (10 per minute) and confirmed on the contact endpoint (3 per minute), each per edge-function instance. Daily `pg_cron` purges were added for `chat_sessions`, `contact_messages`, and `demographics_submissions` (180 days). Non-blocking Resend alerting was added for repeated login failures and edge-function errors. Control mapping: SC-5, SI-12, SI-4, AU-5, AU-6.

Finding 2026-07: Third-party dependency vulnerabilities (monitored). A dependency scan found 13 known vulnerabilities. Upgrades and npm overrides reduced these to 6; the remaining 6 are transitive with no patched upstream release (recharts-bundled `lodash`; `@lovable.dev/mcp-js` build tooling) and are accepted as monitored residuals with low real-world exploitability. Control mapping: RA-5, SA-22.

Intentionally not changed. The `access_tokens` rows were left in place because they back the paid Stripe magic-link flow, not beta codes; voiding them would break outstanding paid-customer links. They expire via `expires_at`.

---

10. Known Gaps and Owner Input Required

10.1 Confirmed gaps (control weaknesses stated honestly)

The family policy and procedure (-1) gaps are closed by the CTA policy manual (cta-policies.md). The 2026-07-27 remediation (Section 9) closed several technical gaps previously listed here: system-use notification (AC-8), data-retention scheduling (SI-12), audit-log tamper-resistance (AU-9), the beta-code and SECURITY DEFINER findings, and server-side password enforcement (now a residual rather than an open gap). The weaknesses below are what remain.

1. **IA-5 server-side password length (residual).** The 12-character minimum is now enforced server-side through the `secure-signup` edge function, but the raw `/auth/v1/signup` endpoint is not subject to it because Lovable Cloud exposes no "before user created" hook. HIBP breached-password checking applies on both paths.
2. **AU-6 scheduled review.** Automated alerting now fires on a defined login-failure pattern and on edge-function errors, but there is no scheduled, documented human review of audit records.
3. **CA-7 / SI-4 continuous monitoring.** Defined alert triggers now exist; there is still no monitoring strategy, metrics, SIEM, or dashboard beyond Cloudflare Analytics and the alerts.
4. **CP-2 / CP-4 / CP-10 contingency planning.** No written contingency plan and no tested recovery.
5. **CP-9 backups.** Backups are platform-provided only; the owner runs no independent backup and has not tested a restore.
6. **IR-4 / IR-8 incident response.** No defined incident handling process and no written incident response plan, though Section 9 now records several same-day remediations. The incident response policy exists (IR-1); the detailed plan and handling procedure do not.
7. **RA-2 / RA-3 risk assessment.** LOW categorization is asserted, not formally documented; no formal risk assessment exists.
8. **CM-2 / CM-4 configuration management.** No documented configuration baseline and no security impact analysis step for changes.
9. **Rate limiting is per-instance.** The application rate limits (magic-token, contact) run per edge-function instance, not as a distributed limiter; they blunt brute force but are not a WAF.

10. **Dependency residuals.** Six transitive dependency vulnerabilities remain with no patched upstream version available (recharts-bundled `lodash`; `@lovable.dev/mcp-js` build tooling), accepted as monitored residuals with low real-world exploitability.
11. **SA-22 dependency support calendar.** Dependency versions and vulnerabilities are now scanned, but there is no formal end-of-support calendar per component.

10.2 Owner input required (CONFIRM items)

1. **Seventh Cloudflare domain.** The Cloudflare account "eBiz Market" holds 7 domains. Confirm the identity of the seventh and confirm which domains redirect versus host or route mail. (Bears on CM-8, Section 2.)
2. **Cloudflare Worker `empty-disk-1010`.** Confirm whether this Worker (0 invocations) is in the boundary or leftover; remove if not needed. (Bears on CM-7, CM-8, SR-12.)
3. **DNSSEC.** Confirm whether DNSSEC is enabled for `communitytechaid.ai`. (Bears on SC-20.)
4. **Marketing collaborator agreement.** Confirm whether a written access or confidentiality agreement covers the marketing collaborator who holds the second account. (Bears on PS-6, AC-2.)
5. **Provider attestations.** If auditor evidence is needed for inherited physical and platform controls, confirm whether provider compliance reports (for example SOC 2) are available for Lovable, Cloudflare, and Stripe. (Bears on the PE family, SC-28, CA-2.)

10.3 Structural constraint worth stating

Because Lovable Cloud is a managed Supabase instance the owner does not own (no service role key, no direct database URL, no separate Supabase dashboard), several controls the owner would otherwise implement or verify directly are constrained to what the Lovable editor exposes. This constraint is not a failure of diligence; it is a property of the hosting model, and it is disclosed here so that inherited and unverifiable controls are not mistaken for owner-operated ones.

End of document. Control titles verified against the NIST SP 800-53 Rev 5 catalog on 2026-07-27; remediation update applied 2026-07-27 (Section 9 Remediation Log). This plan describes the system as built and names its gaps deliberately.